



HIPAA TECHNICAL SAFEGUARDS AUDIT

HIPAA Technical Safeguards Audit Report

Target

demo/patient-portal

Scan date

May 16, 2026 · 15:29 Venezuela Standard Time

Findings

17 total · Risk Score 0/100

Executive Summary

The Aegis scanner identified 17 potential HIPAA Technical Safeguards violations in the codebase (15 critical, 2 high). The aggregate risk score is 0/100. Critical and high findings should be remediated before any environment handling Protected Health Information is exposed to end users. Each finding below cites the controlling 45 CFR §164.312 provision and includes prescriptive remediation guidance.

Severity	Count
● CRITICAL	15
● HIGH	2
● MEDIUM	0
● LOW	0
Total	17

RISK SCORE

0 / 100

$\max(0, 100 - (10 \times \text{crit} + 5 \times \text{high} + 2 \times \text{med} + 1 \times \text{low}))$

Rule Coverage

- **AC-1** Access Control · 45 CFR §164.312(a)(1) · 2 findings
- **AC-2** Automatic Logoff · 45 CFR §164.312(a)(2)(iii) · 1 finding
- **AC-3** Person or Entity Authentication · 45 CFR §164.312(d) · 1 finding
- **AU-1** Audit Controls · 45 CFR §164.312(b) · 7 findings
- **EN-1** Encryption and Decryption · 45 CFR §164.312(a)(2)(iv) · 3 findings
- **IN-1** Integrity · 45 CFR §164.312(c)(1) · 1 finding
- **TR-1** Transmission Security · 45 CFR §164.312(e)(1) · 2 findings

Findings Index

ID	Rule	CFR	Severity	File:Line
15cdd4f6	TR-1 Transmission Security	§164.312(e)(1)	● CRITICAL	config/database.js:16
ad3c70d2	EN-1 Encryption and Decryption	§164.312(a)(2)(iv)	● CRITICAL	models/Patient.js:22
231664e8	EN-1 Encryption and Decryption	§164.312(a)(2)(iv)	● CRITICAL	models/Patient.js:31
5a189338	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/admin.js:30
e8fb4e66	AC-1 Access Control	§164.312(a)(1)	● CRITICAL	routes/appointments.js:9
688be5d7	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/appointments.js:9
c8716e70	AC-3 Person or Entity Authentication	§164.312(d)	● CRITICAL	routes/auth.js:19
ce0fc463	TR-1 Transmission Security	§164.312(e)(1)	● CRITICAL	routes/medications.js:10
b0bb6cae	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/medications.js:12
31a20452	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/medications.js:20
41529fa2	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/medications.js:43
d8d401ec	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/medications.js:48
de6e15cf	AC-1 Access Control	§164.312(a)(1)	● CRITICAL	routes/patients.js:24
a7bf1c05	AU-1 Audit Controls	§164.312(b)	● CRITICAL	routes/patients.js:24
1b8e66fb	EN-1 Encryption and Decryption	§164.312(a)(2)(iv)	● CRITICAL	routes/patients.js:41
893802f9	AC-2 Automatic Logoff	§164.312(a)(2)(iii)	● HIGH	middleware/session.js:10
0ba9732e	IN-1 Integrity	§164.312(c)(1)	● HIGH	routes/medications.js:50

Findings Detail

CRITICAL · 15 findings**45 CFR § 164.312(e)(1)****CRITICAL****Transmission Security** · TR-1 · ID 15cdd4f6

config/database.js:16-16

EVIDENCE

```
ssl: false,
```

WHY THIS IS A VIOLATION

Database connection has ssl explicitly disabled. PHI flowing to the database is transmitted in cleartext.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(e)(1) – recommended remediation
1. Enable SSL/TLS for database connections: set dialectOptions.ssl to true or 'require'
2. Use HTTPS URLs for all external API calls (https:// not http://)
3. Ensure all PHI transmission uses encrypted channels.
```

45 CFR § 164.312(a)(2)(iv)**CRITICAL****Encryption and Decryption** · EN-1 · ID ad3c70d2

models/Patient.js:22-25

EVIDENCE

```
ssn: {
  type: DataTypes.STRING,
  allowNull: false,
},
```

WHY THIS IS A VIOLATION

PHI field 'ssn' is defined without encryption. Sensitive data should be encrypted at rest.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(2)(iv) – recommended remediation
1. For Sequelize models: Use encryption hooks or encrypted field types for PHI fields like SSN.
2. For assignments: Encrypt PHI data before storing (e.g., patient.ssn = encrypt(req.body.ssn)).
3. Consider using libraries like crypto-js or sequelize-encrypted for field-level encryption.
```

45 CFR § 164.312(a)(2)(iv)**CRITICAL****Encryption and Decryption** · EN-1 · ID 231664e8

models/Patient.js:31-33

EVIDENCE

```
diagnosis: {  
  type: DataTypes.TEXT,  
},
```

WHY THIS IS A VIOLATION

PHI field 'diagnosis' is defined without encryption. Sensitive data should be encrypted at rest.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(2)(iv) – recommended remediation  
1. For Sequelize models: Use encryption hooks or encrypted field types for PHI fields  
   like SSN.  
2. For assignments: Encrypt PHI data before storing (e.g., patient.ssn =  
   encrypt(req.body.ssn)).  
3. Consider using libraries like crypto-js or sequelize-encrypted for field-level  
   encryption.
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID 5a189338

routes/admin.js:30-36

EVIDENCE

```
router.get('/audit', requireAuth, requireAdmin, async (req, res) => {  
  const rows = await AuditLog.findAll({  
    order: [['occurred_at', 'DESC']],  
    limit: 200,  
  });  
  res.json(rows);  
});
```

WHY THIS IS A VIOLATION

PHI route GET /audit does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation  
Implement audit logging for all PHI access. If AuditLog model exists, ensure  
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource  
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(a)(1)**CRITICAL****Access Control** · AC-1 · ID e8fb4e66

routes/appointments.js:9-15

EVIDENCE

```
router.get('/:patientId', async (req, res) => {
  const rows = await Appointment.findAll({
    where: { patient_id: req.params.patientId },
    order: [['scheduled_for', 'DESC']],
  });
  res.json(rows);
});
```

WHY THIS IS A VIOLATION

Route GET /:patientId accesses PHI but has no authentication middleware. Found middleware: none

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(1) – recommended remediation
Add authentication middleware (e.g., requireAuth, authenticate, isAuthenticated) to all
routes that access Protected Health Information (PHI). Example:
router.get('/patients/:id', requireAuth, async (req, res) => { ... })
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID 688be5d7

routes/appointments.js:9-15

EVIDENCE

```
router.get('/:patientId', async (req, res) => {
  const rows = await Appointment.findAll({
    where: { patient_id: req.params.patientId },
    order: [['scheduled_for', 'DESC']],
  });
  res.json(rows);
});
```

WHY THIS IS A VIOLATION

PHI route GET /:patientId does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation
Implement audit logging for all PHI access. If AuditLog model exists, ensure
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(d)**CRITICAL****Person or Entity Authentication** · AC-3 · ID c8716e70

routes/auth.js:19-19

EVIDENCE

```
if (username === 'admin' && password === 'admin') {
```

WHY THIS IS A VIOLATION

Credential identifier compared against a string literal — hardcoded credentials bypass real authentication and are easily extracted from source.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(d) – recommended remediation
Remove hardcoded credentials. Use environment variables or secure credential management
systems. Implement proper authentication with password hashing (e.g., bcrypt) and secure
credential storage.
```

45 CFR § 164.312(e)(1)**CRITICAL****Transmission Security** · TR-1 · ID ce0fc463

routes/medications.js:10-10

EVIDENCE

```
|| 'http://internal-pharmacy-api/v1/prescriptions';
```

WHY THIS IS A VIOLATION

Insecure http:// URL ('http://internal-pharmacy-api/v1/prescriptions') used in HTTP client code. PHI in flight must travel over TLS — use https:// instead.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(e)(1) – recommended remediation
1. Enable SSL/TLS for database connections: set dialectOptions.ssl to true or 'require'
2. Use HTTPS URLs for all external API calls (https:// not http://)
3. Ensure all PHI transmission uses encrypted channels.
```


45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID b0bb6cae

routes/medications.js:12-18

EVIDENCE

```
router.get('/:patientId', requireAuth, async (req, res) => {  
  const rows = await Medication.findAll({  
    where: { patient_id: req.params.patientId },  
    order: [['started_at', 'DESC']],  
  });  
  res.json(rows);  
});
```

WHY THIS IS A VIOLATION

PHI route GET `/:patientId` does not call `AuditLog.create()`. Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation  
Implement audit logging for all PHI access. If AuditLog model exists, ensure  
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource  
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID 31a20452

routes/medications.js:20-41

EVIDENCE

```
router.post('/', requireAuth, async (req, res) => {
  const med = await Medication.create({
    patient_id: req.body.patient_id,
    name: req.body.name,
    dosage: req.body.dosage,
    frequency: req.body.frequency,
    prescriber: req.body.prescriber,
  });

  try {
    await axios.post(PHARMACY_API, {
      patient_id: med.patient_id,
      drug: med.name,
      ... (9 more lines)
    });
  }
});
```

WHY THIS IS A VIOLATION

PHI route POST / does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation
Implement audit logging for all PHI access. If AuditLog model exists, ensure
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID 41529fa2

routes/medications.js:43-46

EVIDENCE

```
router.get('/lookup/:rxcuri', requireAuth, async (req, res) => {
  const resp = await axios.get(`${PHARMACY_API}/lookup/${req.params.rxcuri}`);
  res.json(resp.data);
});
```

WHY THIS IS A VIOLATION

PHI route GET /lookup/:rxcuri does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation
Implement audit logging for all PHI access. If AuditLog model exists, ensure
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID d8d401ec

routes/medications.js:48-55

EVIDENCE

```
router.post('/discontinue', requireAuth, async (req, res) => {
  const { patient_id, status } = req.body;
  const [count] = await Medication.update(
    { status },
    { where: { patient_id } }
  );
  res.json({ updated: count });
});
```

WHY THIS IS A VIOLATION

PHI route POST /discontinue does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation
Implement audit logging for all PHI access. If AuditLog model exists, ensure
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(a)(1)**CRITICAL****Access Control** · AC-1 · ID de6e15cf

routes/patients.js:24-28

EVIDENCE

```
router.get('/:id', async (req, res) => {
  const patient = await Patient.findPk(req.params.id);
  if (!patient) return res.status(404).json({ error: 'not found' });
  res.json(patient);
});
```

WHY THIS IS A VIOLATION

Route GET /:id accesses PHI but has no authentication middleware. Found middleware: none

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(1) – recommended remediation
Add authentication middleware (e.g., requireAuth, authenticate, isAuthenticated) to all
routes that access Protected Health Information (PHI). Example:
router.get('/patients/:id', requireAuth, async (req, res) => { ... })
```

45 CFR § 164.312(b)**CRITICAL****Audit Controls** · AU-1 · ID a7bf1c05

routes/patients.js:24-28

EVIDENCE

```
router.get('/:id', async (req, res) => {
  const patient = await Patient.findByPk(req.params.id);
  if (!patient) return res.status(404).json({ error: 'not found' });
  res.json(patient);
});
```

WHY THIS IS A VIOLATION

PHI route GET /:id does not call AuditLog.create(). Every read/write of PHI must produce an audit log entry.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(b) – recommended remediation
Implement audit logging for all PHI access. If AuditLog model exists, ensure
AuditLog.create() is called for all sensitive operations. Log: actor, action, resource
type, resource ID, timestamp, and IP address.
```

45 CFR § 164.312(a)(2)(iv)**CRITICAL****Encryption and Decryption** · EN-1 · ID 1b8e66fb

routes/patients.js:41-41

EVIDENCE

```
patient.ssn = req.body.ssn;
```

WHY THIS IS A VIOLATION

PHI assignment 'patient.ssn' stores plaintext data from request. Encrypt sensitive data before storage.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(2)(iv) – recommended remediation
1. For Sequelize models: Use encryption hooks or encrypted field types for PHI fields
   like SSN.
2. For assignments: Encrypt PHI data before storing (e.g., patient.ssn =
   encrypt(req.body.ssn)).
3. Consider using libraries like crypto-js or sequelize-encrypted for field-level
   encryption.
```

HIGH · 2 findings**45 CFR § 164.312(a)(2)(iii)****HIGH****Automatic Logoff** · AC-2 · ID 893802f9

middleware/session.js:10-10

EVIDENCE

```
maxAge: 86400000,
```

WHY THIS IS A VIOLATION

Session cookie maxAge is 86400000 ms (1440 minutes), exceeding the HIPAA-recommended 30-minute automatic logoff window.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(a)(2)(iii) – recommended remediation
Set session maxAge to 30 minutes (1800000 ms) or less. Example: session({ cookie: {
maxAge: 1800000 } })
```

45 CFR § 164.312(c)(1)**HIGH****Integrity** · IN-1 · ID 0ba9732e

routes/medications.js:50-53

EVIDENCE

```
const [count] = await Medication.update(
  { status },
  { where: { patient_id } }
);
```

WHY THIS IS A VIOLATION

Medication.update() is scoped by foreign key(s) ['patient_id'] rather than the primary key 'id'. This mass-updates every row sharing that parent and risks overwriting PHI for unrelated records.

RECOMMENDED REMEDIATION

```
// 45 CFR § 164.312(c)(1) – recommended remediation
Scope Model.update() to a specific primary key, not a foreign key. Example:
Model.update(data, { where: { id: specificId } }). A foreign-key where clause (e.g.
patient_id) will overwrite every row owned by that parent – a mass-update violation of
PHI integrity.
```

Appendix A · Rule Catalogue

AC-1 Access Control · 45 CFR § 164.312(a)(1)

CRITICAL

Implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights.

REMEDIATION GUIDANCE

Add authentication middleware (e.g., `requireAuth`, `authenticate`, `isAuthenticated`) to all routes that access Protected Health Information (PHI). Example: `router.get('/patients/:id', requireAuth, async (req, res) => { ... })`

AC-2 Automatic Logoff · 45 CFR § 164.312(a)(2)(iii)

HIGH

Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity.

REMEDIATION GUIDANCE

Set session `maxAge` to 30 minutes (1800000 ms) or less. Example: `session({ cookie: { maxAge: 1800000 } })`

AC-3 Person or Entity Authentication · 45 CFR § 164.312(d)

CRITICAL

Implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed.

REMEDIATION GUIDANCE

Remove hardcoded credentials. Use environment variables or secure credential management systems. Implement proper authentication with password hashing (e.g., `bcrypt`) and secure credential storage.

AU-1 Audit Controls · 45 CFR § 164.312(b)

CRITICAL

Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information.

REMEDIATION GUIDANCE

Implement audit logging for all PHI access. If `AuditLog` model exists, ensure `AuditLog.create()` is called for all sensitive operations. Log: actor, action, resource type, resource ID, timestamp, and IP address.

EN-1 Encryption and Decryption · 45 CFR § 164.312(a)(2)(iv)**CRITICAL**

Implement a mechanism to encrypt and decrypt electronic protected health information.

REMEDATION GUIDANCE

1. For Sequelize models: Use encryption hooks or encrypted field types for PHI fields like SSN.
2. For assignments: Encrypt PHI data before storing (e.g., `patient.ssn = encrypt(req.body.ssn)`).
3. Consider using libraries like `crypto-js` or `sequelize-encrypted` for field-level encryption.

IN-1 Integrity · 45 CFR § 164.312(c)(1)**HIGH**

Implement policies and procedures to protect electronic protected health information from improper alteration or destruction.

REMEDATION GUIDANCE

Scope `Model.update()` to a specific primary key, not a foreign key. Example: `Model.update(data, { where: { id: specificId } })`. A foreign-key where clause (e.g. `patient_id`) will overwrite every row owned by that parent — a mass-update violation of PHI integrity.

TR-1 Transmission Security · 45 CFR § 164.312(e)(1)**CRITICAL**

Implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.

REMEDATION GUIDANCE

1. Enable SSL/TLS for database connections: set `dialectOptions.ssl` to `true` or `'require'`
2. Use HTTPS URLs for all external API calls (`https://` not `http://`)
3. Ensure all PHI transmission uses encrypted channels.

Appendix B · Scan Metadata

Scan target	demo/patient-portal
Generated at	2026-05-16 15:29:48 Venezuela Standard Time
Report ID	6429c60e-f08f-4670-aeca-fa2e68bb01b0
Findings	17
Risk score	0/100
Files with findings	8
Scanner version	0.1.0

Engine	Aegis Static Analyzer · tree-sitter + heuristics
--------	--

Generated by Aegis · Powered by IBM Bob